

사이버 위협 인텔리전스 리포트

CTI-2026-0507-SCARCRUFT

ScarCruft, 연변 게이밍 플랫폼을 통째로 점령한 공급망 공격

*APT37의 sqgame[.]net 침해 — Windows·Android 멀티플랫폼 트로이목마화,
연변 조선족·탈북민 표적 첩보 작전*

BirdCall(zhuagou) Android 신규 버전 · Zoho WorkDrive C&C ·
한국 공인인증서(.p12)·한컴문서(.hwp) 동시 타깃팅 · 중국→북한 도구 계보

TLP:GREEN · 심각도: HIGH · Independent Analysis

발행: Dennis Kim (김호광)
Cyber Threat Intelligence Division · Betalabs Inc.
2026년 5월 7일 발행

문서 정보

리포트 ID	CTI-2026-0507-SCARCRUFT
분류 (Classification)	TLP:GREEN — 대외 공유 가능
유형 (Type)	Threat Actor & Supply-Chain Incident Report
심각도 (Severity)	HIGH — 국가 안보 첩보 작전 · 인적 표적 위해 가능성
대상 산업 (Target Sector)	게이밍 플랫폼 · 모바일 앱 · 한국인 디아스포라 커뮤니티
표적 지역 (Target Region)	중국 연변(延邊) 조선족 자치주 · 한국·북한 국경 지역
위협 행위자 (Threat Actor)	ScarCruft / APT37 / Reaper (북한 연계 첩보 그룹, 2012~)
악성코드 (Malware)	BirdCall (Windows + Android 신규) · RokRAT (1차 적재)
내부 코드명	zhuagou (抓狗) — 중국 해커 커뮤니티 은어 계열
활동 기간 (Activity Window)	2024년 11월 ~ 진행 중 (공개 시점: 2026-05-05 ESET)
1차 자료 (Source)	ESET Research, "A rigged game: ScarCruft compromises gaming platform in a supply-chain attack" (Filip Jurčacko, 2026-05-05)
작성일	2026년 5월 7일
발행	Dennis Kim CYBER-THREAT-INTELLIGENCE-REPORT GitHub Archive https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

1. 요약

2026년 5월 5일, 슬로바키아 보안 기업 ESET이 북한 연계 APT 그룹 ScarCruft(APT37)의 멀티플랫폼 공급망 공격을 공개했다. 표적은 중국 연변(延边) 조선족 자치주 거주민을 대상으로 하는 게이밍 플랫폼 sqgame[.]net이며, 이 플랫폼이 배포하는 Windows 데스크톱 클라이언트 업데이트 패키지와 Android 게임 APK가 모두 트로이목마화되었다.

공격은 2024년 후반부터 최소 18개월 이상 진행 중이며, 본 리포트 작성 시점에도 일부 악성 APK는 sqgame 공식 사이트에 그대로 게시되어 있는 것으로 ESET이 확인했다. ESET은 2025년 12월 sqgame 측에 통보했으나 응답을 받지 못했다.

본 사건의 결정적 이슈는 세 가지다.

첫째, ScarCruft가 그동안 Windows에 한정해 운용해 온 BirdCall 백도어의 Android 포트(zhuagou)를 신규 무기화했다. ESET은 2024년 10월경 만들어진 v1.0부터 2025년 6월경 만들어진 v2.0까지 총 7개 버전을 식별했으며, 이는 단발성 도구가 아니라 수개월간 적극적으로 개발·운용된 모바일 첩보 플랫폼임을 의미한다.

둘째, 표적 파일 확장자 목록에 한국 공인/금융인증서 형식인 **.p12**와 한컴오피스 문서 형식인 **.hwp**가 명시적으로 포함된다. 이는 본 작전이 단순 첩보를 넘어 표적 개인의 한국 금융 자산·정부 문서 접근까지 시야에 둔 정밀 작전임을 시사한다.

셋째, 백도어의 내부 코드명 **zhuagou(抓狗)**는 일반 중국어 사전적 의미가 아닌 **중국권 해커·크랙·게임해커 커뮤니티의 정착된 은어로**, 2012년경부터 정보 수집·계정 탈취·사용자 추적 모듈을 지칭하는 표준 용어다. 이는 본 도구의 계보가 **중국 해커 그룹에서 출발해 북한 ScarCruft가 인수·업그레이드한 흐름**임을 시사한다(상세 §6.1).

⚠️ 잔인한 의미:

연변은 북한 탈북민의 주요 1차 경유지다. 본 작전은 사실상 탈북민·탈북 보조자·인권 활동가의 신원·위치·연락망을 식별하는 데 사용될 수 있으며, 이는 단순한 사이버 보안 사안이 아닌 **인적 안전(physical safety) 위협**으로 해석되어야 한다.

핵심 판단 (Key Judgments)

#	판단	신뢰도
KJ-1	본 작전은 ScarCruft의 기존 TTP와 일치하며, 북한 정찰총국 소속 그룹의 첩보 작전으로 평가된다.	높음
KJ-2	표적은 연변 거주 조선족, 특히 탈북민·탈북 보조자·인권 활동가일 가능성이 가장 높다.	높음
KJ-3	.p12.hwp 동시 타깃팅은 표적의 한국 금융·정부 자산 접근을 명시적 목표로 설정한다.	중간
KJ-4	BirdCall의 Android 포트는 단발성 도구가 아닌 수개월 단위로 개발·운용되는 ScarCruft의 신규 모바일 첩보 플랫폼이다. v1.0(2024.10) → v2.0(2025.06) 7개 버전 발견.	높음
KJ-5	sqgame 측 응답 부재 및 일부 악성 APK 잔존은 본 공격 표면이 현재도 활성임을 의미한다.	높음
KJ-6	한국 거주 조선족·탈북민·연계 NGO·종교단체 종사자 역시 동일·유사 캠페인의 잠재 표적군에 포함된다.	중간
KJ-7	내부 코드명 zhuagou(抓狗)의 해커 은어 분석을 종합할 때, 본 도구의 직계 계보는 중국 해커 커뮤니티의 정보 수집 모듈에서 출발하여 ScarCruft가 인수·업그레이드한 것으로 평가된다.	중간-높음

2. 사건 개요

2.1 표적 플랫폼 프로파일

플랫폼명	sqgame (정식 도메인: sqgame[.]net, 다운로드 도메인: sqgame.com[.]cn)
서비스 성격	연변 지역 전통 카드·보드 게임 (대표작: 延边红十 / Yanbian Red Ten, 新画图 / New Drawing)
지원 플랫폼	Windows · Android · iOS (iOS는 트로이목마화 미발견)
호스팅 IP	39.106.249[.]68 — Hangzhou Alibaba Advertising Co., Ltd.
호스팅 변경 시점	2024-06-01 (현재 IP로)
이용자층	연변 조선족 자치주 거주민이 주로 하는 고스톱 및 로컬 카드게임)

2.2 공격 체인 요약

플랫폼	침해 경로	적재 페이로드
Windows	sqgame 데스크톱 클라이언트 업데이트 패키지 변조 (xiazai.sqgame.com[.]cn/dating/20240429.zip)	트로이목마화된 mono.dll → 다운로드 → RokRAT → BirdCall
Android	sqgame 다운로드 페이지의 두 게임 APK 재패키징 및 재서명 (ybht.apk, sqybhs.apk)	Android BirdCall (zhuagou) 직접 적재
iOS	트로이목마화 흔적 없음. ScarCruft가 Apple 심사 회피 비용을 회피한 것으로 추정 탈북자의 아이폰 사용자가 희박함	—

2.3 표적층(Victimology)

ESET 분석에 따르면 표적은 다음 우선순위로 평가된다:

- 연변 거주 조선족 — sqgame 자체가 연변 전통 게임에 특화된 플랫폼이므로 1 차 표적군 자명
- 탈북민 / 탈북 보조자(brokers, NGO 종사자, 종교 활동가) — 연변은 북한 탈북 1 차 경유지로서 북한 정권의 최우선 추적 대상
- 한국 거주 조선족 가족 — 표적 단말기에서 수집되는 연락처·SMS·통화 기록을 통한 2 차 표적 식별
- 한국 정부·금융 자산 접근권자 — .p12.hwp 확장자 타깃팅이 시사하는 별도 표적군

3. 사건 타임라인

일시	이벤트
2012 ~	ScarCruft 그룹 활동 개시 (MITRE G0067 등재)
2021	BirdCall (Windows) 최초 발견. ESET 비공개 인텔리전스로 ScarCruft 귀속. 한국 보안 벤더(S2W, AhnLab)도 동 시기 "RokRAT의 진화형(Matryoshka 변종)"으로 공개 보고.
2024-06-01	sqgame 사이트가 현재 IP(39.106.249[.]68, Alibaba)로 이전 — 본 캠페인의 인프라 정착 추정 시점
2024-10경	Android BirdCall v1.0 컴파일 (ESET 분석 추정)
2024-11경	sqgame Windows 클라이언트 업데이트 패키지의 mono.dll이 트로이목마화된 상태로 ESET 텔레메트리에 최초 관측
2024-11-04	한국 침해 사이트 www.lawwell.co[.]kr (SK Broadband) 셸코드 호스팅 시작
2025-03 ~ 07	추가 한국 사이트들(1980food.co[.]kr, inodea[.]com, colorncopy.co[.]kr, sejonghaeun[.]com, cndsoft.co[.]kr)이 셸코드·설정·정상 mono 라이브러리 호스팅에 차례로 동원
2025-06경	Android BirdCall v2.0 컴파일 (난독화 강화)
2025-10	ESET이 트로이목마화된 Android APK 2종을 sqgame 사이트에서 직접 확인
2025-12	ESET, sqgame 측에 침해 통보. 응답 없음.
2026-05-05	ESET, WeLiveSecurity에 공식 분석 공개 (Filip Jurčacko)
2026-05-05 시점	일부 악성 APK는 여전히 sqgame 공식 사이트에 게시되어 있는 것으로 ESET 확인
2026-05-07	본 CTI 분석 발행

2024년 6월 → 2024년 10~11월 갭의 의미

인프라 이전부터 트로이목마화 시작까지 약 4~5개월의 사전 작업 기간이 존재했다. 이는 ScarCruft가 sqgame 침해 후 즉시 무기화한 것이 아니라, 충분한 사전 정찰과 도구 적응(특히 Android 포트 신규 개발)을 거친 정밀 작전임을 시사한다.

4. 공격 체인 기술 분석

4.1 Windows 체인 — 4 단계 다중 적재

단계	컴포넌트	동작
① 업데이트 변조	xiazai.sqgame.com[.]cn/dating/20240429.zip	정식 sqgame 클라이언트가 합법적 업데이트 채널을 통 해 자동 다운로드
② 트로이목 마화 mono.dll	95BDB94F6767A3CCE6D92363BBF5BC84B786BDB0	정상 mono 라이브러리에 추가 코드·데이터 패치 형태 로 내장. 다운로더 포함
③ 다운로더 동작	(메모리 내)	(a) 분석 도구·VM 환경 점검 — 발견 시 정지 (b) sqgame 클라이언트 프로세 스 탐지 (c) 침해된 한국 사 이트에서 셸코드 다운로드· 실행 (d) 클라이언트 프로세 스 종료 (e) 정상 mono.dll로 자동 교체 — 흔적 제거
④ RokRAT → BirdCall	셸코드 페이로드	RokRAT 백도어 적재 후, RokRAT가 추가로 더 정교 한 BirdCall을 다운로드·설치

🔑 주목할 TTP: 자기 정화(self-cleanup) 단계.

다운로더가 작업 완료 후 트로이목마화된 mono.dll을 정상 버전으로 자동 교체하여, 감
염 후 정적 분석에서 침해 흔적을 완전히 제거

이는 ScarCruft가 장기 잠복(long-dwell) 작전을 위해 설계한 운영 보안(OPSEC) 패턴이
다.

4.2 Android 체인 - 재패키징 모델

ScarCruft는 sqgame의 게임 소스코드 자체에는 접근하지 못한 것으로 평가된다. 대신 이미 빌드된 정상 APK를 디컴파일·재패키징·재서명하는 방식을 사용

변조 항목	내용
AndroidManifest.xml 수정	진입점 액티비티를 악성 코드 (com.example.zhuagou.SplashScreen 또는 com.mob.util.MobSs)로 변경
백도어 액티비티/서비스 추가	악성 코드 실행을 위한 신규 컴포넌트 등록
권한 추가	연락처·SMS·통화기록·외부 저장소·녹음·위치 등 광범위 권한 요구
정상 게임 실행 유지	백도어 시작 후 원본 게임 액티비티를 호출 — 사용자가 이상을 감지하지 못하도록 함

4.3 C&C 인프라 — 합법 클라우드 서비스 이용

ScarCruft의 일관된 TTP인 합법 클라우드 서비스 기반 C&C가 본 캠페인에서도 유지된다. Android BirdCall은 다음 3개 클라우드 제공자를 지원하나, 실제 운용은 Zoho WorkDrive에 한정된다.

클라우드	운용 여부	용도
Zoho WorkDrive	✓ 활성 운용 (12개 계정 식별)	명령 폴링 및 데이터 반출
pCloud	백도어 코드 내 지원, 실 미사용	예비 채널
Yandex Disk	백도어 코드 내 지원, 실 미사용	예비 채널

식별된 12개 Zoho 계정은 모두 영문명 위장 패턴(tomasalfred37@, kalimaxim279@, smithbentley0617@ 등)을 사용한다. 이는 한국·중국명 사용 시 분석가의 즉각적 의심을 피하기 위한 위장으로 평가된다.

4.4 침해된 한국 웹사이트 - 인프라 호스팅 자원

ScarCruft가 셸코드, BirdCall 설정 이미지(JPG 오버레이 인코딩), 정상 mono 라이브러리를 호스팅하기 위해 침해한 한국 측 인프라는 다음과 같다.

도메인	IP	호스팅사	용도
1980food.co[.]kr	211.239.117[.]117	Hostway IDC	Android BirdCall 설정 이미지
inodea[.]com	114.108.128[.]157	LG DACOM	Android BirdCall 설정 이미지
www.lawwell.co[.]kr	221.143.43[.]214	SK Broadband	셸코드 + 정상 mono 라이브러리
colorncopy.co[.]kr / swr.co[.]kr	222.231.2[.]20	LG DACOM	셸코드
sejonghaeun[.]com	222.231.2[.]23	(IP Manager)	정상 mono 라이브러리
cndsoft.co[.]kr	222.231.2[.]41	(IP Manager)	셸코드

📌 국내 함의:

6개 한국 도메인이 단일 캠페인의 호스팅 자원으로 동원되었다는 사실은 국내 중소기업자 웹호스팅 환경의 보안 위생이 북한 APT의 선호 운용 자원이 되어 있음을 재확인시킨다.

KISA·과기정통부의 중소기업자 보안 점검 프로그램의 실효성을 재검토할 필요가 있다.

5. ScarCraft / APT37 위협 행위자 프로파일

5.1 그룹 개요

별칭	ScarCraft · APT37 · Reaper · Group123 · Ricochet Chollima · Inky Squid
활동 시기	2012 ~ 현재
추정 귀속	북한 정찰총국(RGB) 산하 첩보 단위 (MITRE G0067)
주 표적	한국 정부·국방·언론·탈북민, 일본·중동·동남아 일부
주 동기	첩보(espionage) — 금융 동기 약함 (Lazarus 등과 차별점)
차별 TTP	합법 클라우드 C&C, 한컴오피스(.hwp) 익스플로잇, Flash 제로데이 활용 이력, 한국어 디코이

5.2 BirdCall — ScarCraft의 시그니처 백도어

BirdCall은 2021년 ESET이 비공개 인텔리전스 보고를 통해 ScarCraft에 귀속한 Windows C++ 백도어다. 한국 보안 벤더 S2W와 AhnLab은 동 시기 이를 "RokRAT의 진화형 (Matryoshka 변종)"으로 공개 보고한 바 있다. 즉 BirdCall은 ScarCraft의 핵심 백도어 패밀리 (RokRAT 계열) 내에서도 상위 정교화 단계의 도구다.

5.3 Lazarus와의 구별

ScarCraft는 종종 Lazarus와 혼동되나, 다음과 같은 명확한 차이가 있다:

구분	ScarCraft (APT37)	Lazarus
모체 기관	정찰총국 첩보 단위	정찰총국 + 노동당 41소 등
주 동기	순수 첩보	첩보 + 외화 획득(금융 범죄)
표적 자산	정부 문서, 인적 정보, 통신	정부 + 금융기관·암호화폐 거래소·DeFi

구분	ScarCrufft (APT37)	Lazarus
공급망 공격 패턴	표적군 맞춤 SaaS 침해 (예: sqgame)	광범위 NPM/3CX 등 글로벌 개발자 도구

본 *sqgame* 작전은 *ScarCrufft* 패턴에 정확히 일치한다.

6. BirdCall 백도어 - Android 신규 버전 분석

6.1 내부 코드명 zhuagou(抓狗) — 단순 작명이 아닌 도구 계보의 단서

ESET 보고서가 식별한 Android BirdCall의 내부 코드명은 중국어 zhuagou(抓狗)다. ESET 원문은 이를 "개 잡기(catching dogs)"로 단순 직역하나, 본 분석은 이 명칭이 일반 중국어 사전적 의미를 넘어 중국권 해커 커뮤니티의 정착된 은어임에 주목해야 한다.

6.1.1 중국 해커 커뮤니티에서 zhuagou(抓狗)의 의미

중국권 크랙·악성코드·게임해커 커뮤니티에서 "抓狗"는 약 2012년경부터 다음을 통칭하는 표준 모듈명으로 사용되어 왔다:

- 계정/정보 수집(*account & credential harvesting*) — 사용자명·비밀번호·세션 토큰·인증서 파일
- 사용자 추적(*user tracking*) — 위치·행동·접속 시간·연락망 매핑
- 로그 수집(*log harvesting*) — 키 입력·메시지·통화 기록 등
- 탐지 및 후킹(*detection & hooking*) — 표적 프로세스에 후킹하여 데이터 추출
- 감염 대상 "잡기"(*target acquisition*) — 표적 식별·격리·통제권 확보

즉 "抓狗"는 일반 중국어 화자가 직역할 "개 잡기"가 아니라, 중국 해커권에서 약 14년 가까이 통용된 정보 수집/추적/계정 탈취 모듈의 표준 작명 관행이다. 게임해·트로이목마·뱅킹 멀웨어 분야에서 폭넓게 등장한 유서 깊은 은어다.

6.1.2 본 도구가 zhuagou 로 명명된 의미

ScarCruft가 자신의 Android 백도어를 zhuagou로 명명한 사실은 단순한 작명 취향의 문제가 아니다. 다음 세 가지 의미층을 동시에 포함한다.

층위	해석
표면적(literal)	표적이 "개"로 비유된다는 운영진의 인식 노출. 연변 조선족·탈북민을 추적·포획 대상으로 객체화.
기능적(functional)	백도어가 실제 수행하는 기능(정보 수집·계정 탈취·추적)이 중국 해커권 zhuagou 모듈군의 표준 기능과 정확히 일치.
계보적(genealogical)	도구의 직계 조상이 중국 해커 커뮤니티의 zhuagou 모듈 계열일 가능성. 즉 ScarCruft가 무에서 창조한 도구가 아니라, 기존 중국권 정보 수집 모듈 코드·아이디어·기법을 인수·이식·강화한 결과물일 수 있음.

📌 본 분석의 독자적 기여:

ESET 원문은 zhuagou를 단순 직역("catching dogs")으로 처리했다. 그러나 한국·중국 해커권 동향을 추적해 온 본 CTI 아카이브의 관점에서, **이 작명은 도구 계보의 결정적 단서**다.

ScarCruft가 중국 해커권에서 출발한 zhuagou 계열 모듈을 인수·업그레이드하여 자체 운용에 편입시킨 것으로 판단된다.

6.1.3 중국→북한 도구 인수의 정황 증거

본 가설(KJ-7)을 뒷받침하는 정황은 다음과 같다:

- 공개된 Windows BirdCall 덤프(SHA-1: B06110E0FEB7592872E380B7E3B8F77D80DD1108)는 **2024 년 7 월 15 일 중국에서 VirusTotal 에 업로드**되었다. 이 덤프는 본 캠페인의 BirdCall 과 매우 유사하며, 중국권 보안 연구자 또는 분석가의 채집 흔적임을 시사한다.
- Android 포트의 패키지명에 `com.example.zhuagou.SplashScreen` 이 그대로 사용된 점은, 일반적 패키지 명명 관행(역 DNS 도메인 사용)과 어긋난다. `com.example` 은 Android 개발 튜토리얼의 기본 예제 패키지명으로, **기존 코드 베이스를 빠르게 재포장한 흔적**으로 해석 가능하다.

- ScarCruft의 도구 인수 이력: 본 그룹은 과거에도 RokRAT(2017년 Cisco Talos 최초 분석) 등 외부 도구를 흡수·재가공한 이력이 있다. zhuagou 계보 인수는 이러한 패턴의 연속선상이다.
- 중국→북한 사이버 도구 이전의 광역 패턴: 중국 해커권의 게임핵·뱅킹 트로이목마 도구가 북한·이란·러시아 APT에 흘러들어가는 흐름은 다수 보안 벤더가 보고해 온 현상이다. zhuagou 사례는 이 흐름의 한 사례로 해석 가능하다.

⚠ 신뢰도 한계:

본 절의 분석은 어휘론적·정황적 추론이며, 코드 일치 비교 등 1차 기술적 증거에 의한 단정적 귀속이 아니다.

신뢰도는 "중간-높음"으로 평가한다(KJ-7). 보다 강한 단정적 귀속을 위해서는 zhuagou 계열 중국 해커 도구의 디컴파일 산출물과 본 BirdCall Android의 코드 비교가 추가로 필요하다.

6.2 버전 이력

버전	추정 컴파일 시점	주요 변화
v1.0	2024-10경	초기 배포
v1.3 / v1.5	2025 초~중반	명령 추가, 안정화
v2.0	2025-06경	난독화 강화 (MITRE T1406 적용)

총 7개 버전이 약 8개월간 배포되었다. 평균 5~6주에 한 번 갱신. 이는 단발 도구가 아닌 활성 운용 플랫폼임을 의미하며, OS 업데이트, 백신의 감지 및 업데이트 주기에 따른 백신 우회 패턴을 보이고 있다. 특히 안드로이드의 보안 패치 주기와 상당히 유사하기 때문에 안드로이드 보안 회피에 대한 업데이트가 지속적으로 이루어진 것으로 보인다.

6.3 핵심 기능

기능 카테고리	세부
개인 정보 수집	연락처, SMS 메시지, 통화 기록
파일 수집	외부 저장소 전수 디렉토리 리스팅 → 표적 확장자 파일 스테이징
표적 확장자	.jpg .doc .docx .xls .xlsx .ppt .pptx .txt .hwp .pdf .m4a .p12
화면 캡처	scr 플래그 활성화 시 주기적 스크린샷
음성 녹음	rec 플래그 활성화 시 마이크 주변 녹음 — 현지 시간 19:00~22:00 한정
원격 갱신	MP_SEND_FILE 명령으로 신버전 APK 자동 적재
C&C 통신	HTTPS via okhttp3, Zoho WorkDrive API

🔍 시간 제한 녹음(19~22시)의 운용 의미:

표적이 가족이나 사저인 저녁 모임을 함께 있을 가능성이 가장 높은 저녁 시간대에 한정된 음성 수집은, 단순 자동 수집이 아니라 표적의 가족·연계 인물 파악을 의도한 인적 정보(HUMINT) 보강용 설계로 평가된다.

이는 본 작전의 첩보 성격을 재확인시킨다.

6.4 백그라운드 지속성 — 무음 MP3 트릭

일부 버전에서 ESET이 관찰한 특이 기법: 백그라운드에서 무음 MP3 파일을 무한 루프 재생하여 OS의 백그라운드 프로세스 종료 정책을 회피한다. 이는 음성 녹음 기능 활성화 시 안정적 캡처를 위한 설계로, 모바일 환경에서 백그라운드 첩보 활동의 지속성을 확보하는 비교적 새로운 TTP다.

6.5 명령어 - Windows 부분 집합

Android BirdCall은 Windows 버전의 명령 부분 집합을 구현한다. Android 미구현 명령에는 다음이 포함된다: 셸 실행(MP_ACTION_SHELL), HTTP 포트 스캐닝(MP_ACTION_WEBSCAN), 워드 프로세서 매크로 활성화(MP_ACTIONS_MORE), 브라우저 자격 증명 탈취. 그러나 핵심 첩보 기능은 모두 이식되어 있다.

7. 한국 특화 위협 - .p12 와 .hwp 의 동시 타깃팅

7.1 .p12 — 한국 공인/금융인증서

PKCS#12 컨테이너 포맷인 .p12 파일은 글로벌 표준이지만, 한국에서는 매우 특수한 함의를 가진다.

.p12 파일이 보관하는 한국 자산
공동인증서(구 공인인증서) — 정부24, 홈택스, 인터넷뱅킹, 증권 거래에 필수
금융인증서 — 은행권 공동 발급, 비밀번호+인증서 결합 인증
코드사인 인증서 — 소프트웨어 서명용
이메일 S/MIME 인증서 — 정부·기업 보안 메일

표적의 단말에서 .p12 파일이 탈취되고 그에 대응하는 비밀번호가 키로깅·스크린캡처·SMS 인증번호 가로채기로 함께 확보된다면, 공격자는 표적의 한국 금융 계좌·증권 계좌·정부 민원 시스템에 직접 로그인 가능한 상태에 도달한다. 연변 조선족 다수가 한국 입출국·송금·연금 수령 등으로 한국 인증서를 보유하고 있다는 점에서, 이는 결정적 자산이다.

7.2 .hwp 한컴오피스 문서

.hwp는 한컴 오피스의 표준 포맷으로, 한국 정부·공공기관·일부 한국 기업의 사실상 표준 문서 형식이다. ScarCruft는 과거에도 .hwp 익스플로잇(예: EPS 처리 결함)을 적극 활용한 이력이 있다.

.hwp 표적이 시사하는 정보 유형
정부·공공기관 발송 공식 문서 (출입국, 세무, 복지 등)
한국 NGO·종교단체 발송 문서 (탈북민 지원 NGO 다수가 .hwp 사용)
법무법인·변호사 작성 법률 자료
학교·교회 회보 등 커뮤니티 문서

7.3 두 확장자 동시 타깃팅의 결합 의미

.p12와 .hwp가 동일 백도어의 단일 표적 확장자 목록에 함께 포함되는 것은 우연이 아니다. 이 조합은 표적 운영의 두 축을 동시에 노린다:

축	.hwp	.p12
목적	표적의 한국 사회 활동 매핑 (누구와 무엇을 주고받는가)	표적의 한국 자산 직접 접근
가치	첩보 가치(intel)	작전 가치(operational)
결합 효과	표적의 한국 연계망 식별 → 인증서로 직접 침투	

📌 본 리포트의 독자 가치 판단:

ESET 원문은 표적 확장자 목록을 단순 나열했으나, 한국 보안 커뮤니티 관점에서 이 두 확장자의 결합은 단순 첩보 작전의 부수 효과가 아니라 작전 설계의 핵심 기둥으로 재해석되어야 한다.

본 리포트는 이 해석을 본 사건의 가장 중요한 한국 측 시사점으로 강조한다.

7.4 .m4a — 음성 녹음 파일의 추가 의미

표적 확장자에 .m4a가 포함된 점도 주목된다. 이는 일반적인 음악 파일 포맷이 아니라, iPhone·일부 Android 단말의 기본 녹음 앱이 생성하는 포맷이다. 표적이 자체적으로 녹음한 회의·통화·메모 파일을 수집 대상에 포함한다는 것은, 백도어의 자체 마이크 녹음(시간 제한 19~22시)을 보완하여 표적이 이미 만들어 놓은 녹음 자산까지 노린다는 의미다.

8. 침해 지표 (Indicators of Compromise)

8.1 파일 해시 (SHA-1)

SHA-1	파일명	분류	설명
01A33066FBC6253304C92760916329ABD50C3191	sqybhs.apk	Android/Spy.Agent.EXM	Android BirdCall v2.0 트로이목마화 게임
03E3ECE9F48CF4104AAFC535790CA2FB3C6B26CF	ybht.apk	Android/Spy.Agent.EGE	Android BirdCall v1.3
2B81F78EC4C3F8D6CF8F677D141C5D13C35333AF	sqybhs.apk	Android/Spy.Agent.EGE	Android BirdCall v1.5
59A9B9D47AE36411B277544F25AD2CC955D8DD2C	ybht.apk	Android/Spy.Agent.EGE	Android BirdCall v1.0
7356D7868C81499FB4E720F7C9530E5763B4C1D0	sqybhs.apk	Android/Spy.Agent.EGE	Android BirdCall v1.0
FC0C691DB7E2D2BD3B0B4C1E24D18DF72168B7D9	sqybhs.apk	Android/Spy.Agent.EGE	Android BirdCall v1.5
95BDB94F6767A3CCE6D92363BBF5BC84B786BDB0	mono.dll	Win32/TrojanDownloader.Agent.ILQ	트로이목마화 mono 라이브러리
409C5ACAED587F62F7E23DA47F72C4D9EC3144D9	(다운로더)	Win32/TrojanDownloader.Agent.ILQ	RokRAT 적재 다운로드

SHA-1	파일명	분류	설명
B06110E0FEB7592872E380B7E3B8F77D80DD1108	(BirdCall 덤프)	Win64/Agent.EGN	2024-07-15 중국발 VT 업로드 — 본 캠페인 유사

8.2 네트워크 IoC

1 차 침해 인프라 (sqgame)

- sqgame.com[.]cn / xiazai.sqgame.com[.]cn — **39.106.249[.]68** (Alibaba Hangzhou)
- sqgame[.]net — 침해된 정식 도메인

침해된 한국 호스팅 (페이로드/설정 적재)

- 1980food.co[.]kr — **211.239.117[.]117** — Android BirdCall 설정 이미지
- inodea[.]com — **114.108.128[.]157** — Android BirdCall 설정 이미지
- www.lawwell.co[.]kr — **221.143.43[.]214** — 셸코드 + 정상 mono 라이브러리
- colorncopy.co[.]kr / swr.co[.]kr — **222.231.2[.]20** — 셸코드
- sejonghaeun[.]com — **222.231.2[.]23** — 정상 mono 라이브러리
- cndsoft.co[.]kr — **222.231.2[.]41** — 셸코드

Zoho WorkDrive 계정 (12 개 식별 — Android BirdCall C&C)

- tomasalfred37@zohomail[.]com
- kalimaxim279@zohomail[.]com
- smithbentley0617@zohomail[.]com
- michaelarrow19@zohomail[.]com
- amandakurth94@zohomail[.]com
- rexmedina89@zohomail[.]com
- alishaross751@zohomail[.]com
- jamesdeeds385@zohomail[.]com
- joyceluke505@zohomail[.]com

- marjoriemiller280@zohomail[.]com
- teresadaniels200@zohomail[.]com
- michaelgiesen62@zohomail[.]com

기타

- ipinfo[.]io/json — 위치 정보 수집(합법 서비스, 차단 시 정상 사용 영향 주의)

8.3 행위 기반 탐지 룰 시사

- 한국 IP 에서 단일 시간대(주로 19~22 시)에 Zoho WorkDrive API 로 정기적 통신
- Android 단말에서 **com.example.zhuagou.*** 또는 **com.mob.util.MobSs** 패키지 트리 존재
- 외부 저장소에 **.p12 .hwp** 파일을 동시에 검색하는 앱 행위
- mono.dll 이 단기간(수 분) 내에 변조→정상으로 연이어 교체되는 흔적

9. MITRE ATT&CK 매핑

9.1 Enterprise (Windows 체인)

Tactic	Technique	적용
Resource Development	T1584.004 (Compromise Infrastructure: Server)	한국 6개 사이트 + sqgame 침해
Resource Development	T1585.003 (Establish Accounts: Cloud Accounts)	Zoho WorkDrive 12계정
Resource Development	T1587.001 (Develop Capabilities: Malware)	Android BirdCall 신규 개발
Resource Development	T1608.001 (Stage Capabilities: Upload Malware)	sqgame에 트로이목마 APK 적재
Initial Access	T1195.002 (Supply Chain Compromise: Software)	sqgame 업데이트 서버 변조
Execution	T1059.003 (Windows Command Shell)	BirdCall 셸 명령

Tactic	Technique	적용
Defense Evasion	T1027.013 / T1140 (암호화·디코딩)	mono.dll 패치 셸코드
Defense Evasion	T1070.004 (Indicator Removal: File Deletion)	자기 정화 — 정상 mono 교체
Defense Evasion	T1480.001 (Environmental Keying)	컴퓨터별 키로 적재 체인 암호화
Defense Evasion	T1497 (Sandbox Evasion)	VM·분석도구 점검
Credential Access	T1555 (Credentials from Password Stores)	브라우저 자격 증명
Discovery	T1046 / T1082 / T1083	네트워크·시스템·파일 탐색
Collection	T1005 / T1056.001 / T1113 / T1115 / T1119 / T1125 / T1560	키로깅·스크린샷·클립보드·자동수집·웹캠·아카이브
C2	T1071.001 / T1090 / T1102.002	HTTP/Proxy/양방향 클라우드
Exfiltration	T1020 / T1041 / T1567.002	자동·C2·클라우드 반출

9.2 Mobile (Android 체인)

Tactic	Technique	적용
Initial Access	T1474.003 (Compromise Software Supply Chain)	sqgame APK 트로이목마화
Defense Evasion	T1406 (Obfuscated Files)	v2.0 난독화
Defense Evasion	T1407 (Download New Code at Runtime)	자체 갱신 메커니즘
Defense Evasion	T1541 (Foreground Persistence)	무음 MP3 + startForeground
Discovery	T1420 / T1422 / T1426	파일·네트워크·시스템 탐색
Collection	T1429 (Audio Capture)	마이크 녹음 (19~22시)
Collection	T1430 (Location Tracking)	ipinfo.io 활용
Collection	T1513 (Screen Capture)	스크린샷
Collection	T1532 (Archive Collected Data)	압축·암호화
Collection	T1533 (Data from Local System)	.p12 .hwp 등 표적 확장자

Tactic	Technique	적용
Collection	T1636.002 / .003 / .004	통화기록·연락처·SMS
C2	T1437.001 / T1481.002	HTTPS / Zoho WorkDrive 양방향
Exfiltration	T1646 (Exfiltration Over C2 Channel)	C&C로 반출

10. 대응 권고사항

10.1 P0 — 즉시 조치 (24 시간 내)

대상	조치
sqgame 이용자 (연변·한국)	단말 즉시 격리. ESET·V3·Malwarebytes 풀 스캔. 초기화 후 재설정 강력 권고. 화면·통화·메시지 기록 임의 외부 유출 가능성 가정.
금융·정부 인증서 보유자 중 sqgame 이용자	.p12 파일 즉시 폐기 및 재발급. 모든 인증서 비밀번호 변경. 인터넷뱅킹·정부24·홈택스 최근 30일 거래·로그인 이력 확인.
국내 ISP·CDN	본 IoC §8.2 도메인·IP 차단. 침해 한국 사이트 운영자 통보.
KISA / 금융보안원	침해 한국 호스팅 사이트 운영자 일제 통보 및 정화 점검 권고

10.2 P1 - 단기 조치 (7 일 내)

대상	조치
탈북민 지원 NGO	단체 활동가 단말 일제 점검. 안드로이드는 가능하면 출처 미상 APK 설치 비활성화 + Google Play Protect 강제.
한컴오피스 사용 정부·공공기관	외부 .hwp 첨부파일 발신자 검증 절차 강화. 매크로 비활성화 점검.
국가정보원 국군방첩사령부	ScarCrufft 캠페인 활동성 평가에 본 사건 반영. 동일 TTP의 한국 거주 조선족·탈북민 표적 확장 가능성 평가.
모바일 보안 솔루션 벤더	Android/Spy.Agent.EGE / EXM 시그니처 적용. 표적 확장자 동시 검색 행위 를 추가.

10.3 P2 - 구조적 권고 (30 일 내)

영역	권고
공급망 무결성	게이밍·소셜 앱 업데이트 채널의 코드 서명 검증 의무화 검토. 특히 디아스포라 커뮤니티 대상 앱은 별도 모니터링 트랙.
클라우드 C&C 탐지	Zoho WorkDrive·pCloud·Yandex Disk 등 합법 클라우드 API 호출의 행동 분석 기반 탐지 룰 정립. 단순 차단은 사용자 영향 큼.
인적 안전 (Human Safety)	탈북민·인권 활동가 대상 디지털 위생 교육 프로그램 표준화 (통일부·NGO 연계). 단말 분리 운용(공적/사적), 메신저 격리, .p12 단말 비저장 원칙.
CTI 정보 공유	본 ESET 보고와 같은 1차 자료의 한국어 분석·재배포 체계 강화. 영문 1차 자료에 의존하는 현 구조의 시차를 줄임.

11. 전략적 시사점

11.1 본 사건이 이전 ScarCruft 사건과 다른 점

차원	이전 ScarCruft 작전	sqgame 작전
표적층	한국 정부·국방·언론	민간 디아스포라 커뮤니티
플랫폼	Windows 중심	Windows + Android 멀티플랫폼
공급망 형태	스피어피싱 위주	합법 게이밍 플랫폼 인수형 공급망 공격
도구 계보	자체 개발 RokRAT 계열	중국 zhuagou 모듈 인수·업그레이드 (추정)
인도적 위험	정보 탈취 위주	인적 신원·위치 노출 → 물리적 위해 가능성

11.2 인도적 관점

본 작전의 가장 우려되는 측면은 단순한 데이터 탈취가 아니다. 연변의 조선족·탈북민 단말

에서 수집되는 연락처·SMS·통화기록·위치·녹음은 그 자체로 북한 정권이 표적의 가족·연계망·은신 경로를 식별하는 데 사용 가능한 자료다.

과거 사례를 보면, 북한 정권의 탈북민 추적은 디지털 정찰 → 인적 자산을 통한 현지 추적 → 가족 인질화·강제 송환의 패턴을 보여 왔다. 본 BirdCall 캠페인에서 수집되는 자료는 이 추적 사슬의 첫 단계 자료원으로 충분히 활용 가능하다.

11.3 국가 안보 시사점

본 사건은 다음을 시사한다:

- 1. "한국 외부의 한국인"도 한국 사이버 안보의 책임 영역에 포함되어야 한다.** 연변·중앙아시아·일본의 한국 디아스포라는 북한 APT의 직접 표적이며, 이들에 대한 사이버 보안 지원은 외교·통일 정책의 디지털 차원 의제로 격상되어야 한다.
- 2. 모바일 첩보 플랫폼 시대의 본격화.** Android BirdCall은 ScarCruft의 첫 본격적 모바일 자체 백도어다. 향후 동일 패턴의 캠페인이 Lazarus-Kimsuky 등 타 북한 그룹에서도 확산될 가능성이 높다.
- 3. 합법 클라우드 C&C의 정착.** Zoho WorkDrive·pCloud·Yandex Disk 등 합법 SaaS의 C&C 활용은 더 이상 신기술이 아닌 표준 운용 패턴이다. 차단 일변도 대응은 한계가 명확하며, 행동 기반 탐지로의 전환이 시급하다.
- 4. 국내 중소기업자 호스팅의 보안 문제.** 본 캠페인 한 건에서만 6개 한국 도메인이 침해 호스팅으로 동원되었다. KISA가 운영하는 중소기업자 보안 점검 프로그램의 실효성·도달성 재평가가 필요하다.
- 5. 사이버 도구 인수·계보 추적의 중요성.** zhuagou 사례가 시사하듯, 북한 APT는 무에서 도구를 창조하기보다 기존 중국·러시아권 해커 도구를 인수·재가공하는 패턴을 반복한다. 한국 CTI 분석은 단일 캠페인의 IoC를 넘어 도구 계보(tool genealogy)를 추적하는 분석 역량을 갖춰야 한다. 이는 어휘론·소스코드 비교·운영진 OPSEC 패턴 등 다층적 분석을 요구한다.

📌 최종 판단

본 ScarCruft / sqgame 작전은 국가배후 APT가 디아스포라 커뮤니티 인프라 자체를 인수하여 인적 첩보 자산화한 표본 사례다.

한국 사이버 안보 정책은 이 패턴이 연변에 한정되지 않고, 한국 거주 조선족·중앙아시아 고려인·재일·재미 한국인 커뮤니티의 디지털 인프라(커뮤니티 앱, 동향 매체, 종교·NGO 자체 호스팅)로 확장될 가능성에 선제적으로 대비해야 한다.

12. 참고 문헌

12.1 1 차 자료

- [1] ESET Research / Filip Jurčacko, "A rigged game: ScarCruft compromises gaming platform in a supply-chain attack", WeLiveSecurity, 2026-05-05.
- [2] ESET GitHub IoC repository — eset/malware-ioc/tree/master/scarcruft.
- [3] MITRE ATT&CK G0067 — APT37 (ScarCruft).

12.2 ScarCruft 배경 자료

- [4] ESET, "Who's swimming in South Korean waters? Meet ScarCruft's Dolphin", 2022-11-30.
- [5] S2W, "Matryoshka — Variant of RokRAT (APT37/ScarCruft)", 2021.
- [6] AhnLab Security Emergency Response Center (ASEC), RokRAT 분석 보고서, 2021.

12.3 관련 공급망 공격 비교 자료

- [7] ESET, "Operation NightScout: Supply-chain attack targets online gaming in Asia", 2021-02-01.
- [8] ESET, "Linux malware strengthens links between Lazarus and the 3CX supply-chain attack", 2023-04-20.

12.4 본 CTI 아카이브 관련 리포트

- [9] CTI-2026-0422-MCP — UNC1069 / Sapphire Sleet 등 북한 공급망 오염 시나리오
- [10] CTI-2026-0420-VERCEL — 공급망 공격 패턴 비교 (ShinyHunters)
- [11] CTI-2026-0320-CORUNA — 모바일-제로데이 위협 생태계

부록 A. 용어 정리

용어	정의
ScarCruft (APT37)	2012년부터 활동 중인 북한 연계 첩보 APT 그룹. Reaper, Group123, Inky Squid 등 다수 별칭.
BirdCall	ScarCruft의 시그니처 백도어 패밀리. 2021년 ESET 발견. RokRAT의 진화형. 2024년 Android 포트 추가.
RokRAT	ScarCruft의 1차 적재용 RAT. BirdCall 적재 매개체로 자주 사용됨.
zhuagou (抓狗)	Android BirdCall의 내부 코드명. 일반 중국어로는 "개 잡기". 그러나 중국 해커권에서는 2012년경부터 정보 수집·계정 탈취·사용자 추적 모듈을 지칭하는 표준 은어로 정착. 본 도구 계보가 중국 해커 커뮤니티에서 출발했을 가능성을 시사함.
연변(延边)	중국 길림성 동부의 조선족 자치주. 북한과 국경 접경. 탈북 1차 경유지.
공급망 공격(Supply-Chain Attack)	최종 표적이 아닌 표적이 신뢰하는 제3자(공급자·플랫폼)를 먼저 침해하여 간접 접근하는 공격.
트로이목마화 (Trojanization)	정상 소프트웨어에 악성 코드를 삽입하여 원래 기능을 유지한 채 백도어 기능을 추가하는 행위.
.p12 (PKCS#12)	인증서·개인키 보관용 표준 컨테이너 포맷. 한국에서는 공동인증서·금융인증서 형식으로 광범위 사용.
.hwp	한컴오피스 표준 문서 포맷. 한국 정부·공공기관 사실상 표준.
포어그라운드 지속성 (Foreground Persistence)	Android에서 백그라운드 프로세스 종료 정책을 회피하기 위해 startForeground API 또는 무음 미디어 재생 등을 사용하는 기법.
도구 계보 (Tool Genealogy)	악성 도구의 코드·아이디어·기법이 어느 그룹에서 출발하여 어떤 경로로 다른 그룹에 인수·이전되었는지를 추적하는 CTI 분석 차원.

— 문서 끝 (End of Report) —

© 2026 Dennis Kim · Cyber Threat Intelligence Division
github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

본 리포트는 ESET Research의 공개 자료를 1차로 한 독립적 한국어 분석이며,
ESET-sqgame 관련 조직의 공식 입장과 무관합니다.

TLP:GREEN • CTI-2026-0507-SCARCRUFT • Published: 2026-05-07

"백도어의 코드명이 **zhuagou**였다.

그것은 단순한 작명이 아니라, 표적이 누구인지에 대한 운용진의 인식과 **도구가 어디서 왔는지에 대한 단서**를 동시에 노출했다." — CTI-2026-0507